CyberQuality Static Assessor

Static Cybersecurity Quality Assessment Report

Target	http://127.0.0.1:8765/insecure
Final URL	http://127.0.0.1:8765/insecure
Collected	2026-10-07T18:29:51.330538+00:00
HTTP status	200
Response time	5.5 ms
Overall score	22/100 (Grade F)

Critical	High	Medium	Low	Passed	N/A
0	3	4	3	2	2

Dimension scores

Dimension	Score
Information Exposure	0/100
Session Security	39/100
Transport Security	0/100
Web Security Headers	24/100

Detailed findings

HDR-001 — Content-Security-Policy [FAIL / HIGH]

Category	Web Security Headers
Description	CSP reduces the impact of script injection by restricting allowed content sources.
Evidence	Header not present
Recommendation	Define and test a restrictive Content-Security-Policy appropriate for the application.
Source	HTTP response

SES-001 — Secure cookie attribute [FAIL / HIGH]

Category	Session Security
Description	Secure prevents cookies from being sent over unencrypted HTTP.
Evidence	Assessed cookies: MoodleSession; Secure present on all: False
Recommendation	Mark authentication/session cookies as Secure when HTTPS is used.
Source	Set-Cookie headers

TRN-001 — HTTPS transport [FAIL / HIGH]

Category	Transport Security
Description	Sensitive educational-platform traffic should be protected with HTTPS.
Evidence	Final URL: http://127.0.0.1:8765/insecure
Recommendation	Serve the platform over HTTPS and redirect HTTP requests to HTTPS.
Source	Final request URL

EXP-002 — X-Powered-By disclosure [FAIL / MEDIUM]

Category	Information Exposure
Description	X-Powered-By may disclose framework or runtime information.
Evidence	X-Powered-By: DemoFramework/1.0
Recommendation	Remove X-Powered-By headers unless there is a clear operational need.
Source	HTTP response

EXP-003 — CORS wildcard exposure [FAIL / MEDIUM]

Category	Information Exposure
Description	An unrestricted Access-Control-Allow-Origin can expose resources to cross-origin reads.
Evidence	Access-Control-Allow-Origin: *; credentials=False
Recommendation	Allow only trusted origins for resources that require cross-origin access.
Source	HTTP response

HDR-003 — Clickjacking protection [FAIL / MEDIUM]

Category	Web Security Headers
Description	Frame restrictions reduce clickjacking risk.
Evidence	No effective frame restriction detected

Recommendation	Use CSP frame-ancestors and/or X-Frame-Options where appropriate.
Source	HTTP response

SES-003 — SameSite cookie attribute [FAIL / MEDIUM]

Category	Session Security
Description	SameSite can reduce cross-site request risks for session cookies.
Evidence	Assessed cookies: MoodleSession; SameSite present on all: False
Recommendation	Set an appropriate SameSite value (Lax or Strict unless cross-site use is required).
Source	Set-Cookie headers

EXP-001 — Server version disclosure [FAIL / LOW]

Category	Information Exposure
Description	Detailed server banners can expose implementation and version information.
Evidence	Server: Apache/2.4.58
Recommendation	Suppress detailed product/version banners where operationally feasible.
Source	HTTP response

HDR-004 — Referrer-Policy [FAIL / LOW]

Category	Web Security Headers
Description	Referrer-Policy limits information disclosed in outbound Referer headers.
Evidence	Header not present
Recommendation	Set a Referrer-Policy such as strict-origin-when-cross-origin or stricter where suitable.
Source	HTTP response

HDR-005 — Permissions-Policy [FAIL / LOW]

Category	Web Security Headers
Description	Permissions-Policy restricts access to selected browser capabilities.
Evidence	Header not present
Recommendation	Define a Permissions-Policy that disables unused browser features.
Source	HTTP response

SES-002 — HttpOnly cookie attribute [PASS / HIGH]

Category	Session Security
Description	HttpOnly reduces access to session cookies from client-side scripts.
Evidence	Assessed cookies: MoodleSession; HttpOnly present on all: True
Recommendation	Mark authentication/session cookies as HttpOnly.
Source	Set-Cookie headers

HDR-002 — X-Content-Type-Options [PASS / MEDIUM]

Category	Web Security Headers
Description	The nosniff directive prevents browsers from MIME-sniffing responses.

Evidence	X-Content-Type-Options: nosniff
Recommendation	Set X-Content-Type-Options: nosniff.
Source	HTTP response

TRN-002 — HTTP Strict Transport Security (HSTS) [NOT_APPLICABLE / MEDIUM]

Category	Transport Security
Description	HSTS instructs browsers to use HTTPS for future requests.
Evidence	Header not present
Recommendation	Configure Strict-Transport-Security with an appropriate max-age after HTTPS is stable.
Source	HTTP response

TRN-003 — TLS certificate validity window [NOT_APPLICABLE / MEDIUM]

Category	Transport Security
Description	Certificates close to expiry can interrupt secure access and create operational risk.
Evidence	TLS certificate not applicable to an HTTP target
Recommendation	Renew certificates before expiry and automate renewal where possible.
Source	TLS handshake

Interpretation and scope

This module performs non-destructive, observable rule-based checks against the supplied HTTP(S) endpoint. A finding is evidence for a security-control assessment, not proof that an exploit exists. The score is a transparent weighted summary intended for comparison and prioritization; severe findings should remain visible even when the overall score is high.